

peers negotiate the IPsec parameters needed for data security with ESP and AH. Finally, a uni-directional SA is built between pairs with a special mode known as Quick Mode. The establishment of the Phase 2 security association can use an entirely different algorithm from what's used by Phase 1 – the Diffie Hellman Algorithm -- for more security. This concept is known as Perfect Forward Secrecy (PFS).

IKE Phase 1.5

IKE Phase 1.5 or the Extended Authentication Phase is an optional phase and is commonly used in remote access VPN solutions. IKE Phase 1.5 will enhance security by adding end-user-level authentication.

Commercial VPN gateways from different manufacturers like Cisco, Checkpoint, Juniper, Microsoft, etc, are readily available. Some of those vendors offer both hardware- and software-based solutions for IPsec implementations. Quite a few robust open source solutions like Openswan, StrongVPN, etc, can also be used for IPsec implementations.

Does your IPsec VPN solution offer complete protection?

VPN penetration testing will help the organisation to baseline (identify the loopholes that exist in the present implementation and modify the configuration accordingly to protect itself from known problems) its current VPN security posture, identify threats and weaknesses, and implement a new security policy that will mitigate risks.

Setting up the test lab for VPN pen-testing

GNS3 is a great tool for simulating Cisco devices (and other vendor devices like Juniper too). There are many tutorials on the Internet for IPsec remote access and site-to-VPN configurations using GNS3. One such tutorial is <http://www.blindhog.net/cisco-how-to-configure-an-ipsec-vpn/>. By using a PC with a Core 2 Duo or higher processor with 2 GB RAM, you can completely simulate the test lab. Distros like Ubuntu now have GNS3 in their repository. Command-line installation in Ubuntu is as simple as `sudo apt-get install gns3`. A complete coverage of the GNS3 set-up is beyond the scope of this article. So those who are new to GNS3, visit <http://www.gns3.net/documentation/> to learn about it.

For this test lab, you need to simulate a router with IPsec support with two interfaces. Do not forget to add the Backtrack PC to the simulated Internet region of your test lab set-up (external interface of router), as shown in the sample topology (Figure 1). All tests will be performed from the Backtrack PC.

The same test lab set-up can also be arranged with

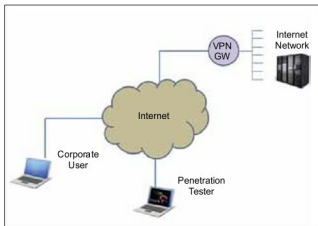


Figure 1: Sample topology

other solutions like Checkpoint SPLAT (Secure Platform or SPLAT is a software-based gateway solution from Checkpoint Software), Microsoft Server 2003 or 2008 (configured as an IPsec VPN gateway), etc.

Penetration testing an IPsec VPN

Penetration testing an IPsec VPN includes several phases like:

1. Scanning or identifying the VPN gateway.
2. Fingerprinting the VPN gateway for guessing implementation.
3. PSK mode assessment and PSK sniffing.
4. Offline PSK cracking.
5. Checking for default user accounts.
6. Testing the VPN gateway for vendor specific vulnerabilities.

Scanning or identifying the VPN gateway

To determine the presence of an IPsec VPN gateway, the penetration tester needs to port-scan the target. Most IPsec implementations will be ISAKMP-based. ISAKMP is an application layer key-exchange protocol that provides mechanisms to establish, negotiate, modify and delete Security Associations. ISAKMP uses UDP port 500, so a direct UDP port-scan on the suspected VPN gateway may give you the results. You can use Nmap or Ike-scan for this.

Scanning with Nmap

A direct port-scan on the VPN gateway with this powerful open source scanner provides supplemental information on the presence of the VPN gateway. Nmap can later be used at the fingerprinting phase for version or OS identification.

```
root@bt:~# nmap -sU -p 500 172.16.21.200
Starting Nmap 5.51 (http://nmap.org) at 2011-11-26 10:56 IST
Nmap scan report for 172.16.21.200
Host is up (0.0036s latency).
PORT      STATE SERVICE
```